AWESOME CYBER SECURITY HEAVEN · REALM DOSSIER · 2026 EDITION

# The Armory

## Offensive Security, Pentesting & Bug Bounty Tools

| 68 | 409,559 | 97% | 65 |
|---|---|---|---|
| FREE TOOLS | COMBINED STARS | ON GITHUB | ACTIVE IN 2026 |

68 tools · ← Back to the main list · Data verified **2026-11-01** (re-verified monthly)

## CURATOR'S NOTES

The workhorse realm — what you load onto a VPS before a bug-bounty session. Injection proof engines, parameter mining, crawl-and-fuzz chains dominate. We license-check hard here because copyleft contamination matters when findings end up in commercial reports.

## MAINTENANCE SNAPSHOT (2026-11-01)

- **Active in the last 30 days:** 56 of 66 tracked GitHub repos (85%)
- **Quiet classics (no push in 12+ months, still listed):** Ghauri
- **Earliest entries:** graudit (2009), WhatWeb (2010), Metasploit Framework (2011)

*Part of Awesome Cyber Security Heaven — 535 curated free tools across 14 realms*

## FLAGSHIP PICKS — THE HEAVYWEIGHTS

| TOOL | ★ STARS | CREATED | LAST PUSH | WHAT IT DOES |
|---|---|---|---|---|
| Metasploit Framework | 39.3k | 2011 | 2026-10-30 ✅ | Metasploit Framework |
| sqlmap | 38.8k | 2012 | 2026-10-30 ✅ | Automatic SQL injection and database takeover tool |
| Nuclei | 32.5k | 2020 | 2026-10-30 ✅ | Nuclei is a fast, customizable vulnerability scanner powered by the global security community and built on a s… |
| masscan | 26.1k | 2013 | 2026-10-05 ✅ | TCP port scanner, spews SYN packets asynchronously, scanning entire Internet in under 5 minutes. |
| MobSF | 22.1k | 2015 | 2026-11-01 ✅ | Mobile Security Framework (MobSF) is an automated, all-in-one mobile application (Android/iOS/Windows) pen-tes… |
| RustScan | 20.7k | 2020 | 2026-10-20 ✅ | 🤖 The Modern Port Scanner 🤖 |

## FULL INVENTORY — 68 CURATED TOOLS

ranked by GitHub adoption · 2026-11-01 census · non-GitHub tools listed without stars

| TOOL | ★ STARS | CREATED | LAST PUSH | LICENSE / TIER |
|---|---|---|---|---|
| Metasploit Framework | 39.3k | 2011 | 2026-10-30 ✅ | — the world's most-used pentest framework; thousands of validated modules for exploitation, post-engagement evidence gathering and reporting in authorized tests. Used by professional penetration testers and red teams in authorized engagements; the open-source counterpart to commercial exploitation platforms like Core Impact and Cobalt Strike. |
| sqlmap | 38.8k | 2012 | 2026-10-30 ✅ | — the definitive SQL injection detection and exploitation tool for authorized web application testing. Used by penetration testers everywhere for SQL injection proof; the definitive free SQLi automation tool with no real commercial equal. (GPL-2.0) |

| TOOL | ★ STARS | CREATED | LAST PUSH | LICENSE / TIER |
|---|---|---|---|---|
| Nuclei | 32.5k | 2020 | 2026-10-30 ✅ | — template-driven vulnerability scanner; the huge community template corpus gives it detection breadth no single scanner matches. Used by bug bounty hunters and enterprise security teams alike for template-driven scanning at scale; a free staple that rivals paid web-scanning engines for public attack-surface checks. |
| masscan | 26.1k | 2013 | 2026-10-05 ✅ | — the fastest TCP port scanner on earth; scan the whole internet in minutes — on networks you're authorized to test. Used by researchers and recon teams for internet-scale port discovery. (AGPL-3.0) |
| MobSF | 22.1k | 2015 | 2026-11-01 ✅ | — all-in-one mobile app security: static + dynamic analysis for Android/iOS in a single pipeline. Used by mobile app security testers for static and dynamic analysis; the open-source alternative to commercial mobile app testing suites. (GPL-3.0) |
| RustScan | 20.7k | 2020 | 2026-10-20 ✅ | — modern Rust port scanner that finds open ports in seconds and pipes them straight into Nmap. Used by bug bounty hunters and sysadmins for fast port discovery with Nmap piping; a modern free alternative to legacy scanners. (GPL-3.0) |
| Bettercap | 20.2k | 2018 | 2026-10-26 ✅ | — the Swiss-army knife for authorized network assessments: ARP/DNS spoofing, MITM proxies, WiFi and BLE modules. Used by network penetration testers for authorized MITM analysis; the modern successor to Ettercap in most toolkits. (GPL-3.0) |
| Impacket | 16.2k | 2015 | 2026-10-30 ✅ | — the standard Python library for low-level Windows protocol work (SMB, LDAP, Kerberos); powers wmiexec/secretsdump-class tooling and AD assessments. Used by red teamers and AD security researchers; the Python underpinning of countless offensive and defensive toolkits. |
| OWASP ZAP | 16.1k | 2015 | 2026-11-01 ✅ | — the open-source intercepting proxy and scanner — a full free Burp alternative with CI/CD integration and a big add-on ecosystem. Used by web pentesters, QA teams and bug bounty beginners. |
| THC-Hydra | 12.5k | 2014 | 2026-10-30 ✅ | — the classic parallelized login cracker for 50+ protocols; password audits only on systems you own or are paid to test. Used by pentesters for authorized login audits across 50+ protocols; the classic parallelized cracker with no commercial equal. (AGPL-3.0) |
| Red-Teaming-Toolkit | 10.8k | 2018 | 2026-05-07 | — curated index of adversary-emulation and red-team tradecraft resources. Used by red teamers planning their tooling stack. (curated list) |
| Nikto | 10.8k | 2012 | 2026-10-26 ✅ | — venerable web-server scanner; noisy but thorough on server misconfigurations and default files. Used by web server auditors for two decades; the venerable free complement to commercial web scanners' misconfiguration checks. (GPL-3.0; DB files have custom terms) |
| WPScan | 9.8k | 2012 | 2026-10-27 ✅ | — black-box WordPress scanner: plugin/theme enumeration and version-based vuln lookups. Used by WordPress security auditors and managed-service providers; the standard black-box WordPress scanner, free alternative to paid WP security suites. (free for non-commercial use) |
| objection | 9.5k | 2017 | 2026-10-27 ✅ | — Frida-powered runtime exploration toolkit for mobile apps — inspect and manipulate iOS/Android at runtime. Used by mobile pentesters for runtime exploration without jailbreaks; the go-to Frida front-end for mobile engagements. (GPL-3.0) |
| Tsunami | 8.6k | 2020 | 2026-10-06 ✅ | — Google's security scanner for large fleets, focused on reliably exploitable high-severity flaws with few false positives. Used by security teams scanning large fleets of internet-facing services; Google's open-source answer to commercial enterprise web scanners. |
| aircrack-ng | 7.8k | 2018 | 2026-10-09 ✅ | — the complete WiFi security audit suite: capture, inject and audit — the wireless standard for two decades. Used by WiFi security auditors worldwide; the complete free suite replacing any commercial WiFi assessment tool. (GPL-2.0) |

| TOOL | ★ STARS | CREATED | LAST PUSH | LICENSE / TIER |
|---|---|---|---|---|
| MITRE Caldera | 7.5k | 2017 | 2026-10-12 ✅ | — scalable adversary-emulation platform built on ATT&CK; run purple-team exercises that prove your detections actually fire. Used by red teams and purple teams for automated adversary emulation; the open-source alternative to commercial breach-attack-simulation platforms like AttackIQ and SafeBreach. |
| RsaCtfTool | 7.2k | 2015 | 2026-10-23 ✅ | — RSA security-testing tool: attacks weak keys and unprotected disclosures purely offline, for auditors and CTF practice. Used by CTF players and crypto researchers attacking weak RSA keys; a niche free tool with no commercial counterpart. (GPL-3.0) |
| WhatWeb | 7k | 2010 | 2026-04-02 | — identifies what a website is built with — frameworks, CMSs, servers and versions — in one command. Used by recon teams to fingerprint what a site runs on; the standard free tech-identifier behind many commercial recon feeds. (GPL-2.0) |
| Responder | 6.6k | 2016 | 2026-06-10 | — LLMNR/NBT-NS/MDNS poisoner; the fastest way to demonstrate credential-leak exposure on an authorized internal network. Used by internal penetration testers to demonstrate credential exposure on enterprise networks; the canonical LLMNR/NBT-NS poisoner. (GPL-3.0) |
| osmedeus | 6.6k | 2018 | 2026-10-04 ✅ | — workflow engine that chains recon and scanning into scheduled, repeatable attack-surface pipelines. Used by recon teams automating full attack-surface workflows; the free alternative to commercial ASM platforms for scheduled recon. |
| wafw00f | 6.6k | 2014 | 2026-04-19 | — fingerprints the web application firewall sitting in front of a site so you know exactly what you're testing against. Used by pentesters planning engagements to fingerprint WAFs first; the standard free WAF detector. |
| NetExec | 6k | 2023 | 2026-10-31 ✅ | — CrackMapExec's actively maintained successor; audit credential hygiene and service misconfigurations across whole subnets. Used by internal network auditors and AD pentesters for credential-hygiene sweeps. |
| commix | 5.9k | 2015 | 2026-10-31 ✅ | — automated OS command injection detection and exploitation for web tests. Used by web pentesters for command-injection proof; a focused free tool that complements general-purpose commercial scanners. (GPL-3.0) |
| Dalfox | 5.4k | 2020 | 2026-11-01 ✅ | — fast XSS scanner with DOM-aware analysis and a strong payload set; the modern XSS go-to. Used by bug bounty hunters for fast, DOM-aware XSS scanning; a favorite free alternative to Burp's scanner for XSS-only sweeps. |
| OpenVAS Scanner | 4.9k | 2018 | 2026-10-30 ✅ | — Greenbone's open-source vulnerability scanning engine for network and service flaws. Used by security teams running unauthenticated network vulnerability scans; the classic open-source alternative to Nessus, Qualys and Rapid7 InsightVM. (GPL-2.0) |
| afrog | 4.4k | 2022 | 2026-11-01 ✅ | — fast cross-platform vulnerability scanner driven by a 1,700+ community-maintained YAML PoC corpus covering CVE, CNVD, unauthorized-access, default-password and fingerprinting checks. Used by bug bounty hunters and pentesters running corpus-driven scans; the open-source scanner with one of the largest community PoC collections. (MIT) |
| GitTools | 4.2k | 2015 | 2026-09-29 | — recovers an exposed `.git` directory into full source and commit history — audit your servers before attackers do. Used by bug bounty hunters to recover exposed .git directories into full source; the go-to free tool for this bug class. |
| Ghauri | 4.1k | 2022 | 2025-10-04 ⏳ | — a strong sqlmap alternative for error/union/blind SQLi with clever parameter tampering; slower release cadence but unique value. Used by bug bounty hunters for tricky blind, error-based and time-based SQLi. |

| TOOL | ★ STARS | CREATED | LAST PUSH | LICENSE / TIER |
|---|---|---|---|---|
| BloodHound | 3.5k | 2023 | 2026-10-31 ✅ | — maps the shortest attack paths through Active Directory; defenders run it to find and fix their way to Domain Admin. Used by Active Directory pentesters to map hidden attack paths; the standard tool defenders also run to harden AD. |
| kiterunner | 3.3k | 2021 | 2026-07-10 | — API route brute-forcer with method-aware wordlists derived from Swagger specs; dormant upstream, still the reference. Used by API security testers brute-forcing routes with method-aware wordlists; the open-source alternative to commercial API discovery scans. (AGPL-3.0) |
| ettercap | 2.8k | 2012 | 2026-10-26 ✅ | — the veteran MITM analysis suite for ARP poisoning, sniffing and protocol dissection — bettercap's classic sibling. Used by network pentesters and students learning MITM analysis; the veteran suite that inspired later tools like Bettercap. (GPL-2.0) |
| brutespray | 2.6k | 2017 | 2026-11-01 ✅ | — multi-protocol credential brute-forcer that parses Nmap and Nessus output and sprays discovered services, on networks you are authorized to test. Used by pentesters validating default and weak credentials; the classic Python companion to Hydra. (MIT) |
| f8x | 2.2k | 2021 | 2026-10-16 ✅ | — red/blue team environment automation: deploys a full security-tool stack on a fresh Linux host in a few commands. Used by teams standing up engagement or lab boxes fast; a community standard for toolbox provisioning. (Apache-2.0) |
| wapiti | 1.9k | 2020 | 2026-10-05 ✅ | — open-source black-box web vulnerability scanner that crawls and audits without needing a browser. Used by web pentesters and CI pipelines for black-box web scanning; a solid free alternative to paid web vulnerability scanners. (GPL-2.0) |
| InQL | 1.8k | 2018 | 2026-11-01 ✅ | — the reference GraphQL security testing toolkit as a Burp Suite extension: schema introspection analysis, query generation, vulnerability scanning and engine fingerprinting. Used by pentesters auditing GraphQL APIs where classic proxies stop at the surface; doyensec-maintained since 2018. (Apache-2.0) |
| graudit | 1.7k | 2009 | 2026-10-13 ✅ | — grep-based rough source-code auditor: one shell script + 26 regex signature databases (php, sql, xss, secrets, java, python…) for first-pass static review. Used by auditors triaging unfamiliar codebases before deep review; 17 years maintained, v4.1 (2026). (GPL-3.0) |
| Akto | 1.5k | 2023 | 2026-10-31 ✅ | — self-hosted API-security platform that builds a continuous API inventory from mirrored runtime traffic and runs business-logic tests (BOLA, BFLA, OWASP API Top 10) in CI. Used by API security teams testing business-logic flaws generic DAST misses; the open-source alternative to API-scanning SaaS. (MIT) |
| Artemis | 1.3k | 2022 | 2026-10-31 ✅ | — modular web-vulnerability scanning platform that powers CERT Poland's nation-scale scanning (50.6k domains since 2023) and auto-generates human-readable, FP-filtered advisory reports per organization. Used by CSIRTs running continuous constituency scanning with e-mailable advisories; the public blueprint for national-scale detection. (BSD-3-Clause) |
| Pywerview | 1.1k | 2016 | 2026-04-21 | — a Python port of PowerView's AD recon verbs; same questions, no Windows host required. Used by AD pentesters who live on Linux but need PowerView-style Windows enumeration; the Python port of the classic PowerView. (GPL-3.0) |
| jwt-hack | 1.1k | 2020 | 2026-11-01 ✅ | — JWT attack toolkit: cracking, payload generation, alg-confusion and claim-abuse checks for JSON Web Tokens in one CLI. Used by bug bounty hunters and pentesters auditing token-based authentication; the dedicated free toolkit for the JWT bug class.. (MIT) |
| goshs | 1k | 2020 | 2026-10-29 ✅ | — hardened HTTP file-transfer server built for engagements: upload/download, authentication, access control and TLS — the modern replacement for `python -m http.server`. Used by pentesters on engagements as a hardened file-transfer server; the security-hardened alternative to spinning up ad-hoc Python servers. |

| TOOL | ★ STARS | CREATED | LAST PUSH | LICENSE / TIER |
|---|---|---|---|---|
| h5i | 887 | 2026 | 2026-10-31 ✅ | — agent-native web-security workspace: deterministic recon, secrets scanning, DOM post-message auditing and CI regression checks — fully usable without any LLM key. Used by security engineers wanting agent-native, deterministic web checks; a newer open alternative to dashboard-driven commercial scanners. (Apache-2.0) |
| Prism X | 836 | 2023 | 2026-10-26 ✅ | — automated enterprise network security risk detection in the AWVS/fscan class. Used by internal teams risk-scoring their own networks; the free enterprise-web risk scanner. (Apache-2.0) |
| OpenTRAP | 767 | 2026 | 2026-10-31 ✅ | — Free open-source Burp Suite alternative: an intercepting proxy with Repeater, Intruder, a Collaborator-style OAST server and the built-in OWASP ZAP scanner in one desktop suite. Used by web pentesters who want a full proxy workbench without a license; the open alternative built on the ZAP engine.. (AGPL-3.0) |
| Realm | 644 | 2022 | 2026-11-01 ✅ | — open-source adversary-emulation framework with cross-platform implants and Terraform-driven C2 infrastructure for authorized red teams. Used by red teams running repeatable, scoped adversary emulation; the open-source alternative to commercial adversary-simulation platforms. (GPL-3.0) |
| OXO | 586 | 2021 | 2026-10-30 ✅ | — pip-installable security-scanning orchestrator that composes Docker-image agents (nmap, nuclei, ZAP, subfinder…) into typed asset scan graphs with a CLI + GraphQL API. Used by security engineers chaining multi-tool pipelines without glue code; scans IPs, domains, links, files and mobile apps. (Apache-2.0) |
| authz0 | 429 | 2022 | 2026-10-14 ✅ | — CLI broken-access-control tester that replays the same URL set under multiple roles' credentials from a YAML template and flags unauthorized responses. Used by pentesters proving BOLA/authz gaps in minutes instead of hours; role-pair replay made repeatable. (MIT) |
| Nightingale | 315 | 2020 | 2026-11-01 ✅ | — dockerized pentest environment preconfigured with the essential VAPT toolset. Used by pentesters and training labs that want a reproducible toolbox; the Docker alternative to hand-built pentest VMs. (GPL-3.0) |
| crossfyre-toolchain | 256 | 2025 | 2026-11-01 ✅ | — Recon-to-scan toolchain of five Rust engines — subdomain discovery, port scanning, content fuzzing, fingerprinting and vulnerability checks — plus a self-hosted OAST server that confirms each finding before it reports it. Used by bug bounty hunters running fast terminal-first pipelines; the Rust-native alternative to stitched-together shell toolkits.. (Apache-2.0) |
| pphack | 247 | 2024 | 2026-10-22 ✅ | — advanced client-side prototype-pollution scanner for JavaScript-heavy web apps. Used by bug bounty hunters auditing front-end pollution sinks; the dedicated free scanner for this bug class. (MIT) |
| jiraffe | 206 | 2020 | 2026-04-02 | — Jira recon and security auditing: version fingerprinting, gadget/permission checks and CVE mapping for authorized instances. Used by bug bounty hunters targeting Atlassian deployments; a focused free exploitation kit for the Jira bug class. (MIT) |
| unKover | 126 | 2026 | 2026-10-13 ✅ | — the 403 access-bypass tester: a 13-technique battery (path rewrites, header tricks, HTTP method and version shifts) that turns forbidden endpoints into authorized access. Used by web pentesters proving 403s are misconfigurations during engagements; the focused free alternative to commercial authz-testing modules. (MIT per README) |
| PWN | 86 | 2022 | 2026-10-27 ✅ | — Ruby offensive-security automation framework that orchestrates Burp, Nessus, OpenVAS, ZAP and other engines into scripted authorized engagements. Used by pentesters chaining commercial and open engines from one Ruby CLI; the glue layer for multi-engine engagements. (MIT) |
| Nullock | 41 | 2026 | 2026-09-30 | — zero-telemetry HTTP/2 and WebSocket-native Burp alternative with a plugin ecosystem. Used by privacy-conscious web testers; the telemetry-free Burp alternative. (MIT) |

| TOOL | ★ STARS | CREATED | LAST PUSH | LICENSE / TIER |
|---|---|---|---|---|
| rcekit | 28 | 2025 | 2026-10-31 ✅ | — zero-dependency RCE confirmation toolkit with false-positive-resistant sink tiering. Used by pentesters confirming command-injection findings safely; the confirmation tier for injection testing. (MIT) |
| Hakscan | 15 | 2026 | 2026-10-31 ✅ | — Fast, self-contained vulnerability scanner shipped as a single Go binary — covers web apps, APKs and binaries, extensible with JSON and nuclei YAML templates. Used by bug bounty hunters wanting one-binary scanning across target types; the portable free scanner for quick triage.. (MIT) |
| Sniper | 14 | 2026 | 2026-10-29 ✅ | — fast Rust-native intercepting proxy with passive scanning and AI agent support. Used by web testers wanting a lightweight daily proxy; the Rust alternative for intercepting work. (MIT) |
| pentool | 10 | 2026 | 2026-10-05 ✅ | — console-based Burp alternative with crawler, scanner and CI/CD mode. Used by terminal-first pentesters; the TUI web-testing workbench. (AGPL-3.0, copyleft) |
| WAVSS | 9 | 2025 | 2026-10-22 ✅ | — audit-first web vulnerability scanner for common flaws like SQLi and XSS, with domain-ownership verification, DoS-avoidant pacing and PDF reports with remediation guidance. Used by auditors scanning client sites safely under strict rules of engagement; the audit-focused alternative to exploit-heavy scanners. (no license yet — verify before reuse) |
| VulnRadar | 8 | 2026 | 2026-11-01 ✅ | — Self-hostable web vulnerability scanner with 855+ deterministic checks, stable finding IDs for scan-to-scan diffing, severity-rated reports and actionable fix guidance. Used by teams wanting instant, shareable scan reports without a SaaS subscription; the self-hosted alternative to commercial web scanners.. (GPL-3.0) |
| 2MNY Website Vulnerability Scanner | 4 | 2026 | 2026-11-01 ✅ | — open-source web vulnerability scanner with 200 deterministic modules: OWASP Top 10, XSS/SQLi/SSRF, subdomain takeover, WordPress and AI/LLM surface checks, CVSS-scored evidence and HTML/PDF reports. Self-hosted via Docker. Used by security teams that want evidence-backed, deterministic scanning they can self-host; the open-source alternative to paid scanner SaaS for website attack surfaces. (maintainer's project) |
| perseid | 2 | 2026 | 2026-10-29 ✅ | — memory-bounded Rust Burp alternative with no artificial rate limits. Used by long-running web test sessions; the resource-frugal intercepting proxy. (Apache-2.0) |
| wp-hunter | 2 | 2026 | 2026-10-20 ✅ | — bilingual WordPress plugin triage toolkit with static authorization analysis, archive integrity checks and version monitoring. Used by WordPress security researchers auditing plugins; the plugin-audit toolkit for WP research. (MIT) |
| idoraider | 1 | 2026 | 2026-10-31 ✅ | — Template-driven BOLA/IDOR scanner in Go with dual-token replay: replay the same request under two identities and flag object-level authorization breaks, with zero external dependencies. Used by bug bounty hunters hunting IDOR at scale; the focused free scanner for the BOLA bug class.. (MIT) |
| SoliTools | 0 | 2026 | 2026-10-31 ✅ | — High-accuracy web security scanner in Go built on the rule that a finding must be worth a human's time — precision beats recall at every decision point. Used by bug bounty hunters who want quiet, high-precision scans; the precision-first free scanner.. (MIT) |
| Burp Suite Community Edition | — | — | — | — the industry-standard intercepting proxy for manual web testing; the free tier is where nearly every bug hunter starts. Used by web penetration testers as their daily intercepting proxy; the free tier of the industry-standard Burp Suite Professional. (free, proprietary) |
| Nmap | — | — | — | — the original network mapper: port, service and OS discovery plus the NSE scripting engine for everything from TLS audits to SMB checks. Used by virtually every network security auditor on earth; the open standard that commercial scanners built their discovery phases on. |